

Student name: Temakgolo Pheladi Kemisetso Tolamo

Module: Network and Infrastructure Security

Platform: TryHackMe - Active Directory Basics

TryHackMe username: pheladitolamo

Date: 11 June 2026

Introduction and Expectations

Before starting the Active Directory Basics room on TryHackMe, my knowledge of Active Directory was very limited. I have heard of the term in a Netflix series called *Mr Robot* and understood it was used in organisations but I was not quite sure how it worked behind the scenes to help manage users, computers and access to resources but was confused how administrators control everything from one place. I started this room hoping to gain a clearer understanding of how Active Directory works and why it plays such an important role in organisations. I was eager to understand how Windows domains work and how organisations manage large numbers of users and devices. I expected to gain practical experience using Active Directory tools to manage users, organisational units and permissions and learn skills that are commonly used in the cybersecurity field.

Core Concepts in my own words

Active Directory is a system used in Windows networks to centrally manage users, computers and resources. A Windows Domain is a group of computers and users that are managed together under Active Directory. Windows Domain makes it easier for organisations to manage many users and computers from one central location. Without a domain every computer would need its own user accounts which become difficult to manage as the company grows, this makes it much easier to manage large environments where there are many users and devices. It solves the problem of having to manage every machine individually. A great example is the University of Pretoria whereby students and staff members can log in different computers e.g. from library, computer labs, offices using the same username and password. This is all possible because their accounts are stored centrally in Active Directory instead of each computer individually.

Domain Controller is the server that runs Active Directory. It's basically the brain of the network because it stores user accounts, passwords, computer accounts and security settings. Lets say someone wants to login their account the Domain Controller checks if their username and password are correct and has allows access to certain resources. Because it controls access to the entire domain, the Domain Controller is one of the most important systems in the network and a high-value target for attackers. If an attacker gains control of a Domain Controller they could access user accounts, permissions and sensitive company data.

Organizational Unit (OU) is mainly used to organise users and computers into different departments and categories within Active Directory. A company may have separate OUs for Sales, Marketing, Finance and IT. OUs are used for applying policies and managing structure within the domain. A Security Group is used to give permissions to users more

efficiently. Instead of assigning access to individual users, administrators assign permissions to a group and all members of that group inherit those permissions. A user may belong to many Security Groups because they may need different permissions, however a user can only be placed in one OU because an OU represents where that user is located within the Active Directory structure.

Machine Accounts are accounts that Active Directory automatically creates when a computer joins the domain. They are easy to recognise because the computer name ends with a dollar sign (\$) e.g. TomPC\$. These accounts allow computers to communicate and authenticate with the Domain Controller securely.

Hands-On-Reflection

In the practical part of this room I started by connecting the target Windows machine and explored Active Directory User and Computers. My goal was to understand how information is organised inside Active Directory. The first thing I did was look at the existing Organizational Units and user accounts which helped me understand how departments can be organised to manage many users from one central location instead of configuring each computer individually. I navigated through the domain structure and observed different OUs like Management, Sales, Marketing and Research and Development. I then continued to create a new OU called “Students” and saw how it appeared in the domain structure which helped improve my understanding that OUs are like folders that keep users and computers organised.

The screenshot displays two windows from the Active Directory Users and Computers console. The left window, titled 'Room progress (33%)', shows the properties of an Organizational Unit (OU) named 'Students'. The 'Protect object from accidental deletion' checkbox is checked and highlighted with a red box. The right window, titled 'Active Directory Users and Computers', shows the 'Research and Development Properties' dialog box. The 'Protect object from accidental deletion' checkbox is unchecked. The background shows the domain structure with various OUs like Management, Sales, Marketing, and Research and Development.

Be sure to uncheck the box and try deleting the OU again. You will be prompted to confirm that you want to delete the OU, and as a result, any users, groups or OUs under it will also be deleted.

After deleting the extra OU, you should notice that for some of the departments, the users in the AD don't match the ones in our organisational chart. Create and delete users as needed to match them.

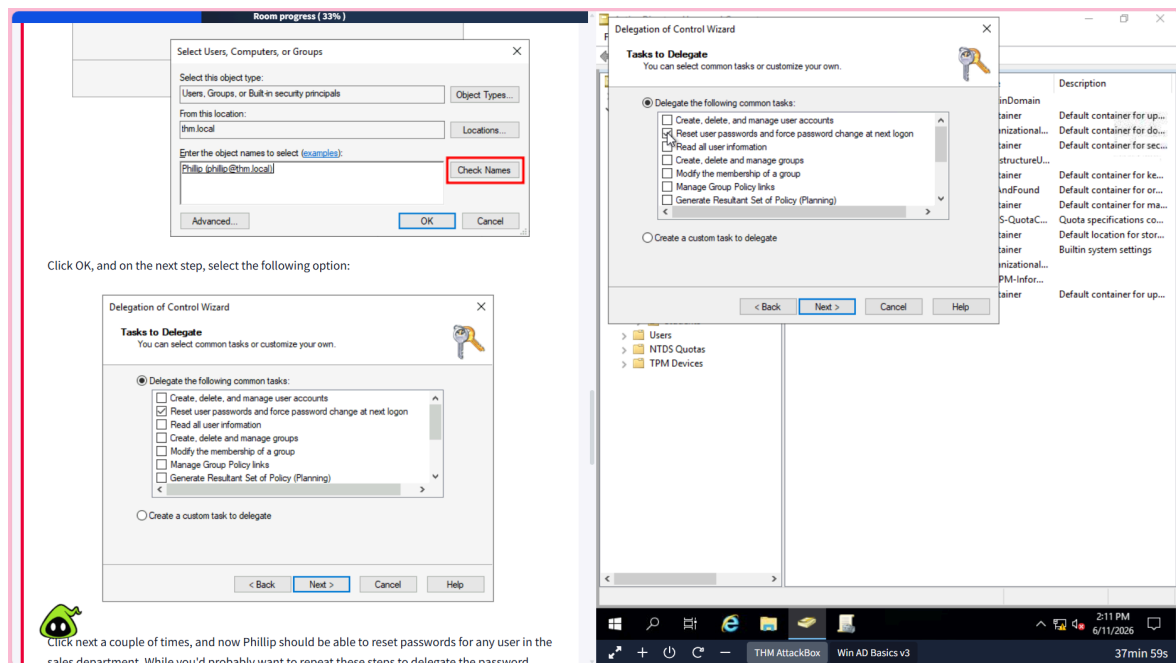
Delegation

One of the nice things you can do in AD is to give specific users some control over some OUs. This process is known as **delegation** and allows you to grant users specific privileges to perform advanced tasks on OUs without needing a Domain Administrator to step in.

One of the most common use cases for this is granting **IT support** the privileges to reset other low-privilege users' passwords. According to our organisational chart, Phillip is in charge of IT support, so we'd probably want to delegate the control of resetting passwords over the Sales, Marketing and Management OUs to him.

For this example, we will delegate control over the Sales OU to Phillip. To delegate control over an OU, you must first select the OU in the console tree.

Screenshot 1: Shows the creation of the Students OU and clicking on the advanced to delete the unused Research and Development OU.



Screenshot 2: Delegating permission to reset passwords to Phillip.

One of the tasks involved removing the Research and Development OU because it was no longer needed. When I initially tried to delete it Active Directory prevented the action because the OU was protected against accidental deletion. After enabling Advanced Features and removing the protection setting, I successfully deleted the OU which showed how Active Directory includes safeguards to prevent administrators from accidentally removing important objects.

Another interesting task was delegation. Delegation means giving someone permission to perform a specific task without giving them full administrator rights. Instead of making Philip a Domain Administrator I only granted him permission to reset passwords for users in Sales department. After that Phillip successfully changed Sophie's password using PowerShell without needing Domain Administrator privileges. This helped me understand the Principle of Least Privilege because Phillip was able to perform his job without having unnecessary administrative rights. I think delegation is a good security practice because not everyone needs Domain Admin access e.g. helpdesk employee may only need permission to reset passwords which gives them only permissions they need reduces the risk of accidental mistakes or abuse.

```
flag - Notepad
File Edit Format View Help
THM{thanks_for_contacting_support}
```

I also created a Workstations OU and moved several workstation computer accounts into it. The lab contained different computer objects, including servers and workstations. By separating them into dedicated OUs I learned how organisations can manage different device types more effectively and apply different security settings to each group. This

showed me how administrators separate different types of devices to make management easier. Finally I explored Group Policy Management and observed how Group Policy Objects can be linked to OUs. The room demonstrated settings such as password policies and automatic workstation locking after periods of inactivity. This helped me understand how a single policy can be applied to multiple users and computers simultaneously ensuring consistent security settings across an organisation.

Authentication and Deep Dive

Active Directory authentication is managed through the Domain Controller, which verifies user credentials when someone logs into the network. I learned that there are two main authentication protocols used in Windows domains: Kerberos and NetNTLM. Kerberos is the main authentication method used in modern Active Directory environments. It uses a ticket-based system instead of sending passwords across the network. The process starts when a user logs in and requests a Ticket Granting Ticket (TGT) from the Domain Controller. The Domain Controller verifies the user's credentials and sends back the TGT. When the user wants to access a service the TGT is used to request another ticket called a TGT ticket. After receiving the service ticket the user presents it to the server they want to access. The server verifies the ticket and grants access if everything is valid. This makes the system more secure because passwords are not repeatedly transmitted.



NetNTLM is an older authentication method which uses a challenge-response system where the server sends a random challenge and the client responds using a information derived from their password hash. The password itself is never sent across the network. The Domain Controller then verifies the response. Kerberos is preferred because it is more secure and efficient than NetNTLM. Understanding NetNTLM is crucial because many organisations still use older systems that rely on it, which are prone to security risks if not properly monitored.

Scaling Active Directory: Trees, Forests and Trusts

As organisations grow a single domain may not be enough to manage all users and systems. In situations whereby the Active Directory may no longer be enough to meet the organisation's administrative, geographical or security requirements; multiple domains need to be created to allow different parts of the organisation to be managed separately while still remaining connected.

A tree is made up of multiple domains that share the same namespace when multiple domains such as thm.local, uk.thm.local and us.thm.local. Each domain operates independently but still belongs to the same organisation; it allows each location to apply its own policies and management practices while remaining part of the same overall structure. A forest is a collection of multiple trees that may have different domain names. This is often used when companies merge or acquire other companies with existing Active Directory systems and need to keep certain parts of the organisation separate for legal, operational or security reasons.

Trust relationships allow authentication between domains in a tree or forest, they determine whether users from one domain can be authenticated by another domain. A one-way trust means that one domain can allow users from another domain to authenticate but not vice versa. A two-way trust that allows both domains to authenticate each other and share resources when permissions are granted. Trust relationships does not automatically grant access to files, folders, applications or other resources. Users must still be given the correct permissions before they can access those resources which provides an additional layer of security and helps organisations maintain control over sensitive information.

Security Lens and Takeaways

From a security perspective Active Directory is both powerful and sensitive. It can become dangerous if it is not managed correctly. The most common attack is abuse of over-privileged accounts like Domain Admin; if too many users have administrative permissions compromising just one account could give an attacker significant control over the network which increases the impact of a compromised account. Legacy authentication methods such as NetNTLM can pose as a risk and may provide attackers with opportunities to capture or misuse authentication information if not properly secured.

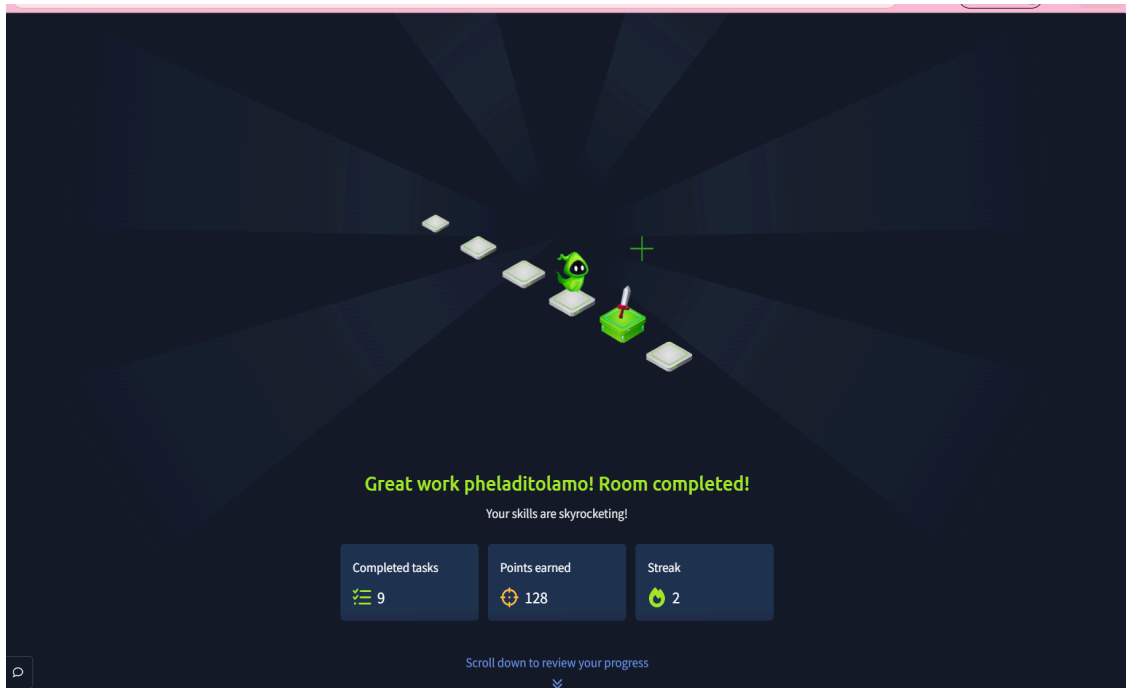
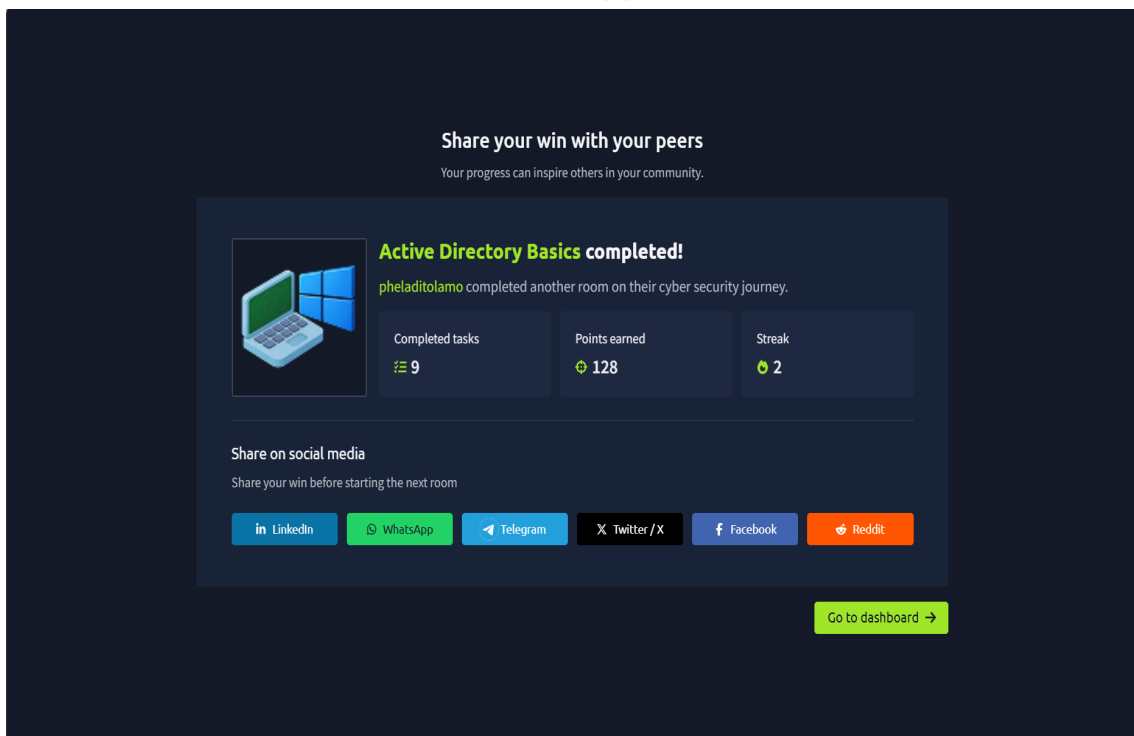
To reduce these risks, organisations should follow the Principle of Least Privilege which means users should only receive the permissions they need to do their jobs. Delegation should be used instead of giving full administrative access, because it allows specific tasks

such as password resets to be assigned without providing full control of the domain. Organisations should regularly review group memberships, enforce strong password policies, enable auditing and monitor Active Directory activity for unusual behaviour.

The most challenging part of this room for me was understanding the authentication process especially how Kerberos tickets are used since multiple tickets are exchanged between the user, Domain Controller and services. However going through the steps on my diagram, slowly helped me understand how users are authenticated without repeatedly sending passwords. Drawing a diagram helped me understand the authentication process and reviewing each step carefully.

Upon completion of the room I now understand why Active Directory is described as the heart of an organisation's network. If it is secure then the organisation has a strong security foundation. I would like to expand my knowledge and learn more about Active Directory attacks, privilege escalation, Kerberos-related attacks and Active Directory hardening techniques. As someone who is still new to cybersecurity, I think understanding Active Directory will be very important for my future learning in helping build a stronger understanding of both offensive and defensive security practices.

Evidence Appendix



Screenshot 3 & 4: Shows the TryHackMe Active Directory Basics room completion.

